

Communications and Cybersecurity

Topic 1 – Introduction to Cybersecurity



Outline

- Introduction
- Cybersecurity concepts
- Security of communications
- Types of attacks

Introduction

Communication

- “Communication is commonly defined as the transmission of information” by [Wikipedia](#)
- “Communication process of exchanging information, ideas, emotions, or meanings between a sender and a receiver through various means...” by [Perplexity.ai](#)

Introduction

Cybersecurity

- “Prevention of damage to, protection of, and restoration of computers, electronic communications systems, electronic communications services, wire communication, and electronic communication, including information contained therein, to ensure its availability, integrity, authentication, confidentiality, and nonrepudiation” by [NIST](#)
- “Cybersecurity encompasses all activities, people, and technology designed to avoid security incidents, data breaches, and loss of critical systems” by [Perplexity.ai](#)

Introduction

Communication & Cybersecurity

- Can we prevent all the damage ?
- Can we protect everything ?

Cybersecurity Concepts – CIA triad

- **Confidentiality** - absence of unauthorized disclosure of a service or piece of information;
- **Integrity** – protection of a service or piece of information against illicit and/or undetected modification;
- **Availability** – protection against possible denials of service caused maliciously



Cybersecurity Concepts – Confidentiality

- The ability of a system to ensure that an asset is viewed only by authorized parties
- Data is disclosed only as intended by the enterprise
- Different levels:
 - Diplomatic and military secrets, product development plans, marketing strategies, student grades, etc.
- A person, process, or program is (or is not) authorized to access a data item in a particular way

Concepts – Data Confidentiality and Privacy

- **Data confidentiality**

- Assures that private or confidential information is not made available or disclosed to unauthorized individuals

- **Privacy**

- Assures that individuals control or influence what information related to them may be collected and stored and by whom and to whom that information may be disclosed

Concepts – Challenges of Confidentiality

- Who determines which people or systems are authorized to access the current system?
 - Access a single bit? the whole collection?
- Can someone who is authorized disclose data to other parties?
- Limitation to functionality?
- Who owns the data?
 - Visiting a web page, who owns the fact link was clicked?
 - User? Web page owner? ISP? All???

Cybersecurity Concepts – Integrity

- The ability of a system to ensure that an asset is modified only by authorized parties
- Enterprise assets are not altered contrary to the enterprise's wishes
- Integrity issues are easy to understand
- Many types hard to detect

Cybersecurity Concepts – Challenges of Integrity

- Harder to delimit than confidentiality, means different things in different contexts:
 - Precise, unmodified, modified only in acceptable ways, modified only by authorized people, consistent, etc.
- The attacker is clever to modify the data in such way that it is very hard to detect
- Even authorized parties can incorrectly modify data

Concepts – Data and System Integrity

- **Data integrity**

- Assures that information and programs are changed only in a specified and authorized manner.

- **System integrity**

- Assures that a system performs its intended function in an unimpaired manner, free from deliberate or inadvertent unauthorized manipulation of the system.

Cybersecurity Concepts – Availability

- The ability of a system to ensure that an asset can be used by any authorized parties
- Enterprise assets, will be accessible when needed for authorized use
- It applies both to data and to services
- It has a broad definition, depending on the system and expectations:
 - present in a usable form, has enough capacity to meet needs, completed in an acceptable period of time, etc.

Concepts – Data and System Availability

- Data availability
 - Assures that information and programs available to be used in their intended way
- System availability
 - Readiness of a system to the provide correct service to the authorized users

Concepts – Challenges of Availability

- Capacity and performance?
- Concurrency: simultaneous access, deadlock management, and exclusive access
- Fair allocation of resources?
- Fault tolerance?
- Usability?
- Availability of authentication services?

Cybersecurity Concepts – Challenges of CIA triad

- Cyber Security seeks to prevent unauthorized viewing (confidentiality) or modification (integrity) while preserving access (availability)
- Can not ALL be maximized at the same time!
 - e.g., confidentiality and availability have conflicting objectives
- It is about **trade-offs and compromises**
- Depends on the organizations and systems, e.g.:
 - Business-critical systems prioritize confidentiality
 - Safety-critical systems prioritize availability

Cybersecurity Concepts – AAA

- **Authentication** – ability to identify and identity or system
- **Authorization** – ability to conceal/grants rights of usage for a specific system
- **Accounting** – ability to confirm that an entity cannot convincingly deny having performed some action

Cybersecurity Concepts – Access Control

- A paradigm of computer security
- A small, centralized control of access is fundamental to preserving confidentiality and integrity
- Is this true for availability?
 - Single points of failure?
- Availability is still a great challenge

Security Communications

- Which application do you use ?
- What is the most relevant security property that you value ?

Security Communications

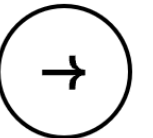
- Example of Instagram

ACCOUNT SECURITY

Strengthen the security of your account so no one has access who shouldn't.

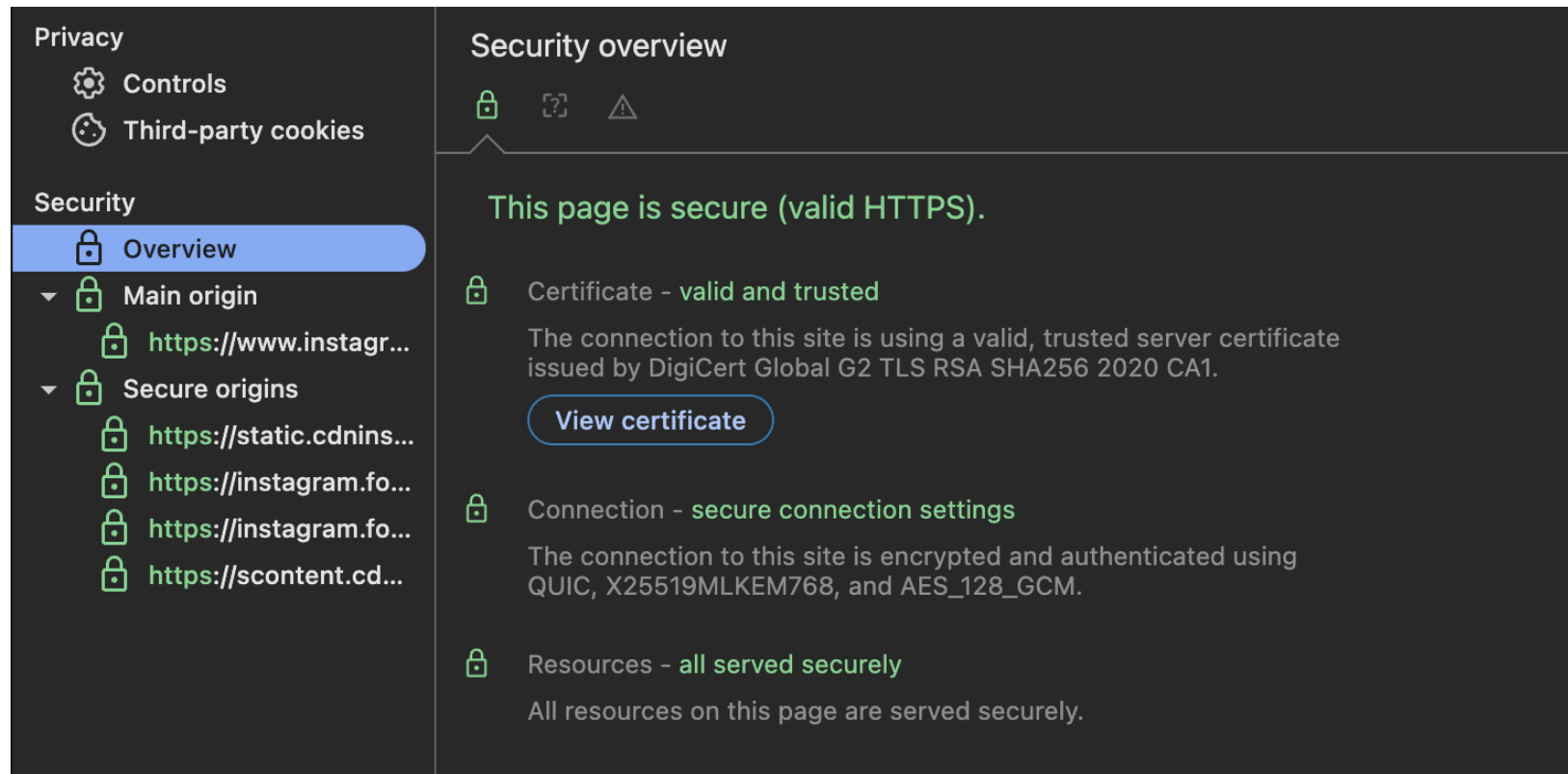
Two-factor authentication

One of the most important things you can do to protect your account is turn on two-factor authentication. Set up an email address, phone number, WhatsApp or third-party app to help us confirm it's you when you log in from a new device. For more info visit our Help Center [here](#).



Security Communications – More Instagram details

▪ Example of Instagram

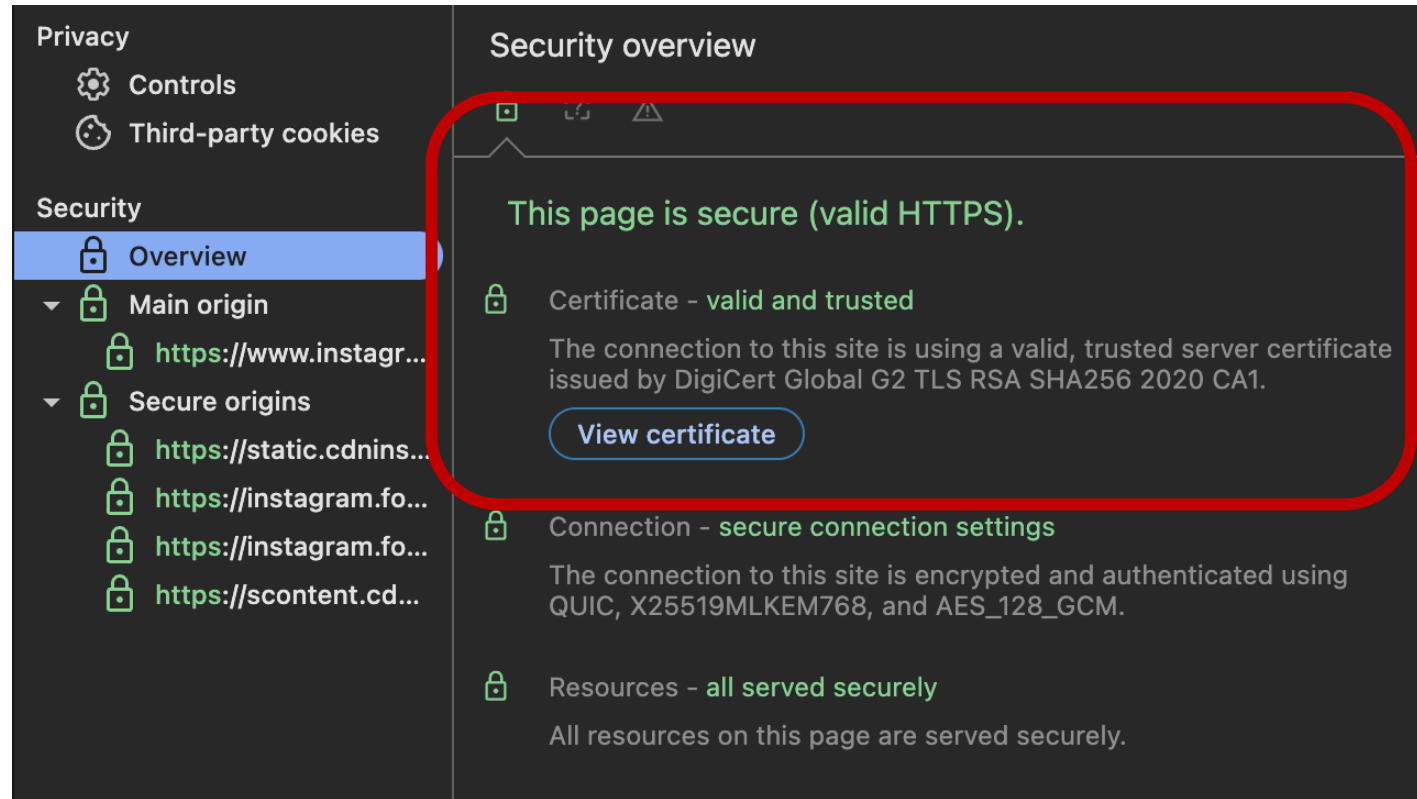


Security Communications – Instagram with HTTPS

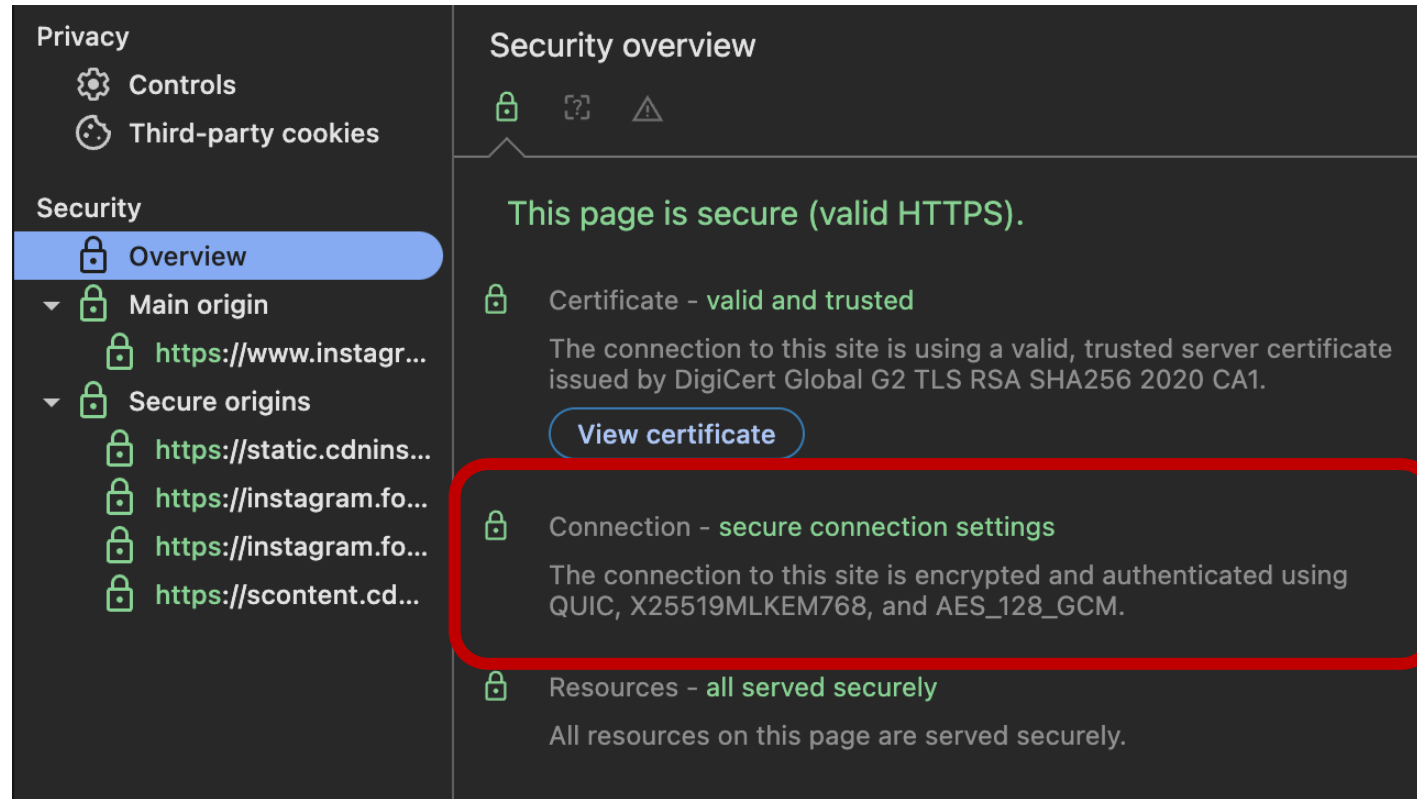


Hyper Text Protocol
Secure HTTPS

- Widely used by
Web applications,
APIs



Security Communications – Instagram with Connection Secure



- Using QUIC Transport Protocol
- Encryption Algorithms (Quantum safe)

Security Communications – Instagram with Secure Resources



All third-party content come from secure resources!

Privacy

Controls

Third-party cookies

Security

Overview

Main origin

Secure origins

https://www.instagram...

https://static.cdnins...

https://instagram.fo...

https://instagram.fo...

https://scontent.cd...

Security overview

This page is secure (valid HTTPS).

Certificate - valid and trusted

The connection to this site is using a valid, trusted server certificate issued by DigiCert Global G2 TLS RSA SHA256 2020 CA1.

View certificate

Connection - secure connection settings

The connection to this site is encrypted and authenticated using QUIC, X25519MLKEM768, and AES_128_GCM.

Resources - all served securely

All resources on this page are served securely.

Origin

https://static.cdninstagram.com

View requests in Network Panel

Connection

Protocol

QUIC

Key exchange

X25519MLKEM768

Server signature

ECDSA with SHA-256

Cipher

AES_128_GCM

Certificate

Subject

*.instagram.com

SAN

*.instagram.com

*.cdninstagram.com

Security Communications - Instagram



- We saw HTTPS protocol to protect data
- We saw QUIC to transport information
- We saw the use of certificates and encryption algorithms
- **Is this enough for securing data/communications using Instagram ?**

Security Communications - Instagram



- **Is this enough for securing data/communications using Instagram ?**
 - No!
 - We need, at least DNS (Domain Name System)

Security Communications – DNS

Domain Name System

- A directory lookup service that provides a mapping between the name of a host on the Internet and its numeric IP address
- Is essential to the functioning of the Internet

```
dig instagram.com A +short  
157.240.212.174
```

Security Communications – DNS

An insecure protocol

- So if another IP address is provided, then we can forge a web site easily:
 - Connecting to 157.157.157. 157 instead of 157.240.212.174
- **Is there any solution for this ?**

Security Communications – DNSSEC

DNS Security Extension

- Consists of a set of new resource record types and modifications to the existing DNS protocol
- In essence, DNSSEC is designed to protect DNS clients from accepting forged or altered DNS resource records It does this by using digital signatures to provide:
 - **Data origin authentication:** ensures that data has originated from the correct source
 - **Data integrity verification:** ensures that the content of a RR has not been modified

```
dig cloudflare.com DNSKEY +short
```

```
256 3 13 oJMRsSz5E4gYzS/q6XDrVU1qMPYIjCWzJa0au8XNEZeqCYKD5ar0IRd8 KqXXFJkqmVfRvMGPmM1x8fGAa2XhSA==
257 3 13 mdsswUyr3DPW132m0i8V9xESWE8jTo0dxCjjnopKl+GqJxpVXckHAeF+ KkxLbxILfDLUT0rAK9iUzy1L53eKGQ==
```

Security Communications – In Instagram using email

- But we can still be tricked by receiving false messages in our mailbox.
 - Our email can be used to recover account
 - Or to receive updates.
- **How can we guarantee protection of email messages ?**

Security Communications - Email

- STARTLS:
 - An SMTP security extension that provides authentication, integrity, non-repudiation and confidentiality for the entire SMTP message by running SMTP over TLS
- S/MIME and PGP
 - Provides authentication, integrity, non-repudiation and confidentiality of the message body carried in SMTP messages

Security Communications - Email

- Sender Policy Framework (SPF)
 - Uses the Domain Name System (DNS) to allow domain owners to create records that associate the domain name with a specific IP address range of authorized message senders.
 - Specified in RFC7208
- DomainKeys Identified Mail (DKIM)
 - Enables an MTA to sign selected headers and the body of a message. This validates the source domain of the mail and provides message body integrity
 - Specified in RFC6376
- Domain-based Message Authentication, Reporting, and Conformance (DMARC)
 - Let senders know the proportionate effectiveness of their SPF and DKIM policies, and signals to receivers what action should be taken in various individual and bulk attack scenarios
 - Specified in RFC 7489.

Security Communications

- Other protocols will be considered along the semester
- Let's pause this example for the time being
- We will come to it in the next class

Attacks terminology

- **Attack**

- “Any kind of malicious activity that attempts to collect, disrupt, deny, degrade, or destroy information system resources or the information itself”, by [NIST](#)

- **Attack Surface**

- “The set of points on the boundary of a system, a system element, or an environment where an attacker can try to enter, cause an effect on, or extract data from, that system, system element, or environment” by [NIST](#)

Attacks terminology

- **Passive Attack**

- “An attack that does not alter systems or data”, by [NIST](#)

- **Active Attack**

- “An attack on a secure communication protocol where the attacker transmits data to the claimant, Credential Service Provider (CSP), verifier, or Relying Party (RP). Examples of active attacks include man-in-the middle (MitM), impersonation, and session hijacking” by [NIST](#)

Types of Attacks

- **Internal Attack**

- Attack promoted by an entity inside an organization
- Both passive or active

- **External attack**

- Attack promoted by an entity from the outside of an organization
- Both passive or active

Types of Passive Attacks

- **Sniffing**

- Unauthorized listening/observation of communications
- Example of Harvest Now Decrypt Later (HNDL), regarding Post Quantum Encryption

- **Traffic Analysis**

- Analysis on encrypted traffic to collect patterns, identities of communication, frequency of messages, ...

Types of Active Attacks

▪ Denial of Service

- Send huge volume of requests to impact availability of services
- Uses different protocols (e.g. DNS flood, SYN Flood, UDP Flood, RST Flood, ICMP Flood, TCP Flood...)

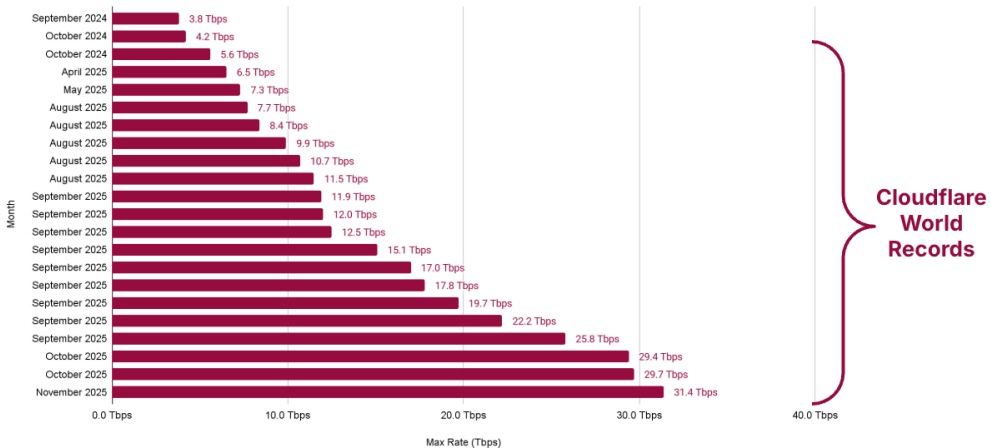
▪ Distributed Denial of Service

- Denial of Service attack amplified by hundreds, millions of devices
- Normally associated with Botnets

Types of Active Attacks - DDoS

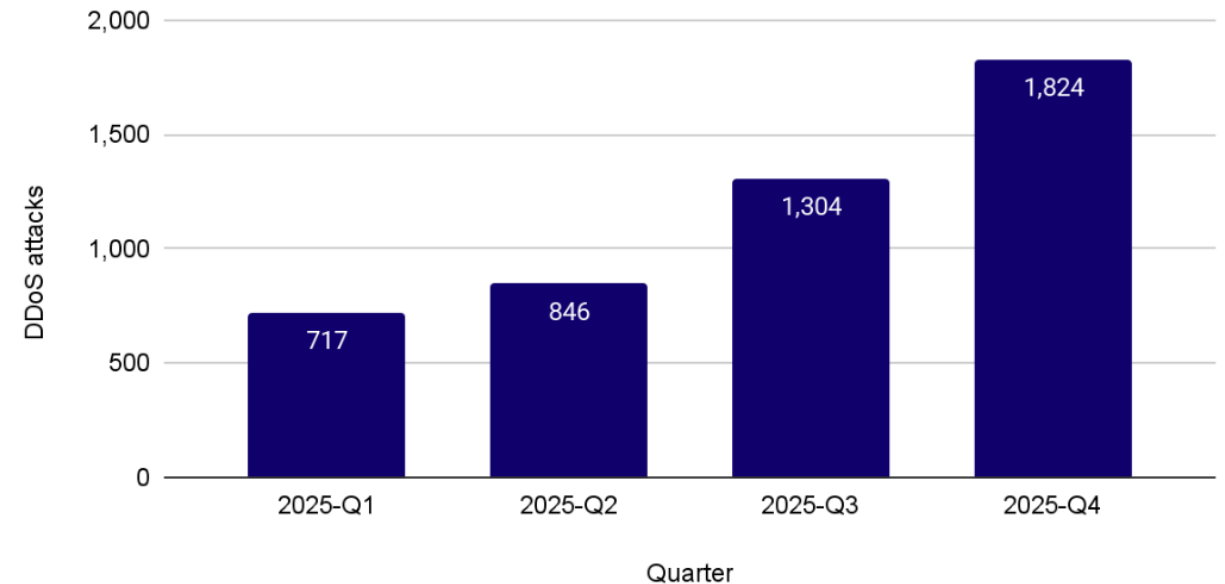
Source [CloudFlare Radar](#) 2025 Q4

Growth in DDoS attack size:
A few of the largest blocked by Cloudflare



Hyper-volumetric DDoS attacks

Network-layer DDoS attacks exceeding 1 Tbps or 1 Bpps



Types of Active Attacks

- **Botnets**

- Attacks that aim to fully control devices/servers/IoT to perform other attacks

- **Data Exfiltration**

- Illegitimate access to data and upload it to other servers, or release it with authorization

Types of Active Attacks

- **Masquerade**

- Attacker assumes false identity to gain access to resources

- **Replay Attack**

- Previous captured traffic is retransmitted to produce unauthorized effects, such as duplicating transactions

- **Man In the Middle (MiTM)**

- Attacker places himself between two entities

Types of Active Attacks

▪ Injection Attacks

- Inject malicious commands in an application to access illegitimately to information.

▪ Ransomware Attacks

- Data is encrypted and a ransom is requested to provide access to data

▪ Session Hijacking

- Attacker is able to steal session information (e.g. session ID)

Types of Active Attacks

- **Advanced Persistent Threats (APTs)**
 - Long-term, targeted attacks where attackers gain and maintain unauthorized access to networks to steal sensitive information
 - Normally with access to computational resources
 - Might be supported by governments

Types of Attacks - Instagram

- Which attack can impact Instagram ?

References

- Schatz, D., Bashroush, R., & Wall, J. (2017). Towards a More Representative Definition of Cyber Security. Journal of Digital Forensics, Security and Law, 12(2). <https://doi.org/10.15394/jdfsl.2017.1476>
- Lawrence Gordon and Martin Loeb, “Managing Cybersecurity Resources: A Cost-Benefit Analysis”, McGraw-Hill
- Ross Anderson, “Security Engineering”, Wiley, online: <http://www.cl.cam.ac.uk/~rja14/book.html>
- Ross Anderson, Rainer Böhme, Richard Clayton, Tyler Moore, “Security Economics and the Internal Market”, ENISA, 2008
- Charles P. Pfleeger, Shari L. Pfleeger, Jonathan Margulies, “Security in Computing”, Prentice Hall, 2015
- Shimon K. Modi, “Biometrics in Identity Management: Concepts to Applications”, Artech House 2011
- William Stallings, Lawrie Brown, “Computer Security: Principles and Practice”, Pearson 2014
- Howard, M.; Pincus, J.; and Wing, J. “Measuring Relative Attack Surfaces.” Workshop on Advanced Developments in Software and Systems Security, 2003.

Question & Comments

?!